

University of Batna 2

جامعة باتنة
UNIVERSITY OF BATNA 2

Chapter 1

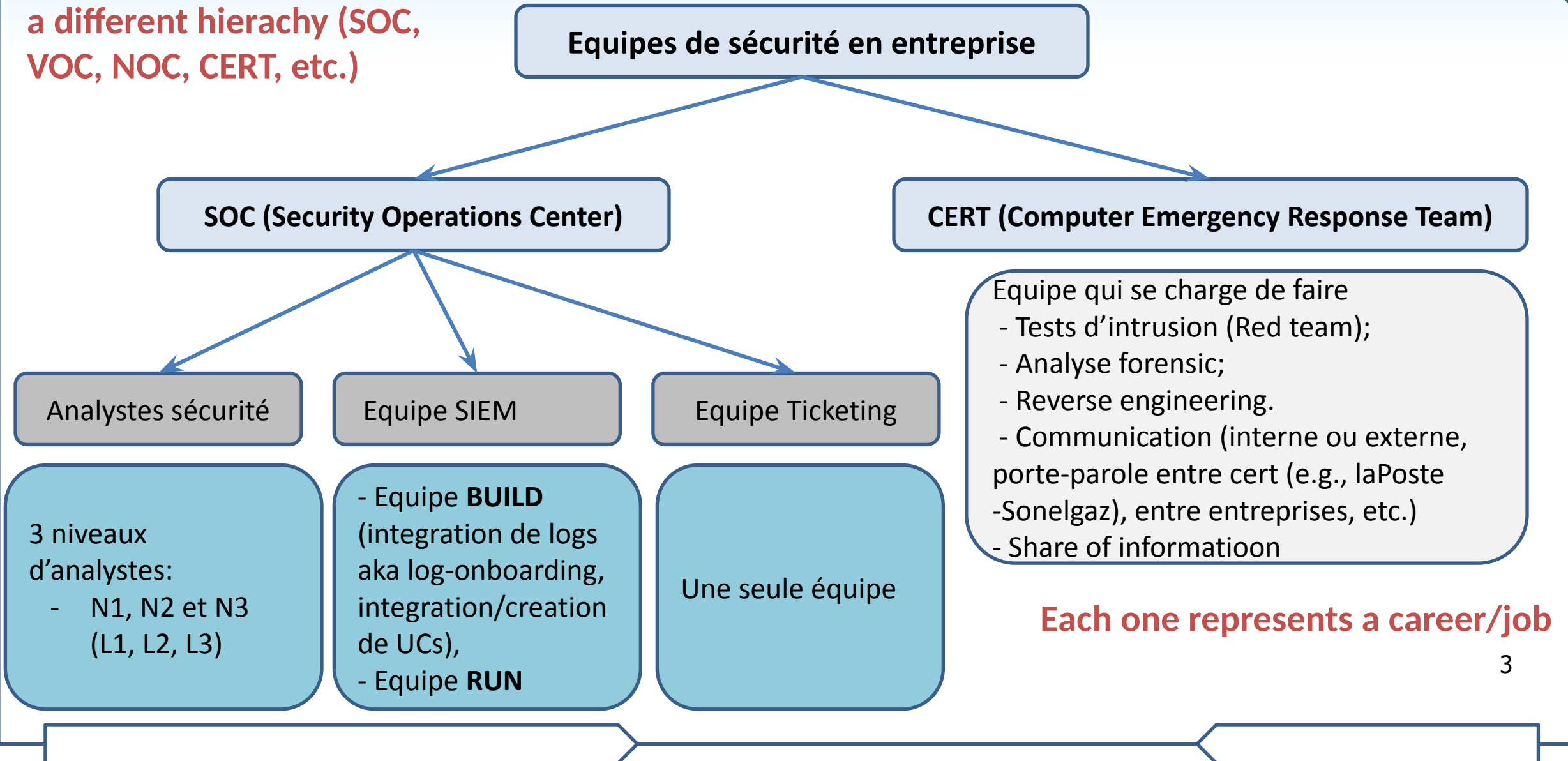
Outils de réponse aux incidents de sécurité en entreprise

جامعة باتنة
UNIVERSITY OF BATNA 2

Equipes de sécurité en entreprise

UNIVERSITY OF BATNA 2

NB: Each company can have a different hierachy (SOC, VOC, NOC, CERT, etc.)



Exemple d'un SOC

Dashboard contains

- Alerts (sound notification for high severity, visual indicators)
- Today's incidents
- Incidents treated today
- Untreated/pending incidents

SLAs (Response Time)

- Critical: 1 hour
- Medium: ~3 hours (average)
- Low: 9–11 hours

Daily alert volume

- 80 to 110 alerts per day



1/ Tâches des analystes SOC: **Exemple**

Analyste N1

- Less qualified (you have everything)
- Réponse aux incidents (analysis and then ticket to proper team/RSSI or forward if unable to solve incident)
- Traitement des emails douteux (20 to 30 email per day)
- **Faire la veille aux vulnérabilités (can be bought as a service) VOC**
- Protéger l'image de l'entreprise
- Surveiller les sites web de l'entreprise exposés sur internet sans chiffrement ou avec un certificat révoqué (using alerts)

Analyste N2

- Assurer des astreintes (on-call duty).
- Réponse aux incidents (coming from N1, and their own).
- Réponse aux demandes spécifiques des responsables client (exemple: RSSI/CISO): police investigations, internal investigations, ..
 - **Décommissionnement des serveurs (OS version, if needed upgrade, remove it otherwise).**
- **Gestion des campagnes malveillantes (phising, teach employees about SE): investigation, report, e.g. 100 users received same malicious emails**
- **Etablir les indicateurs de sécurité** (each month, contact each subsidiary (who paid), report with numbers of triggered incidents per entity, number of closed incidents, incidents in progress and why not responding in this last case)
- **Rédaction des fiches reflexes (procédure à suivre pour faire investigation)**

Analyste N3

- Réponse aux incidents (coming from N2). E.g. N1, N2, CERT,
 - From N1 to CERT
- Analyse de logs (threat hunting) et d'alertes en provenance de SIEM (possibly N2).
- Définir des nouveaux Usecases (MITRE ATT&CK).
- Fine-Tuning des UCs existantes (tuning in pre-prod, fine-tuning in prod. E.g. in both whitelist/blacklist).
- **Qualification des signatures IPS (pcap).**
- Assurer des astreintes (on-call duty): not mandatory.

Questions?

2/ Tâches de l'équipe SIEM au SOC: **Exemple**

BUILD

- Responsable de la conception, installation, configuration initiale, et de la personnalisation de l'outil SIEM.
- Responsable de la mise à jour de l'outil, de surveiller le débit, et le bon fonctionnement

RUN

- Responsable de l'intégration de logs dans le SIEM (can be in some companies in the BUILD).
- Choix des usescases à mettre en place en collaboration avec l'équipe N3 des analystes et en respectant le besoin du client (métier) (15 days in preprod).
- S'assurer que les logs arrivent correctement au niveau du SIEM et que l'outil fonctionne de façon permanente et sans erreur de login, de recherche, d'interface, etc.

3/ Tâches de l'équipe du système de ticketing au SOC: **Exemple**

Real examples of SIEM and ticketing systems will be demonstrated in coming lectures

Équipe Ticketing

- Responsable de l'outil permettant la gestion et le traçage d'incidents.
- N'est pas chargée de la sécurité de l'outil (vendor is responsible for that) mais travaille en étroite collaboration avec les analystes afin de leur faciliter la création et le traitement d'incidents de sécurité (change colors, add fields, etc.).

 **ARCHER**

 **Jira**

servicenow

3/ Tâches de l'équipe du système de ticketing au SOC: **Exemple**

Équipe Ticketing

- Responsable de l'outil permettant la gestion et le traçage des incidents.
- N'est pas chargée de la sécurité de l'outil mais travaille en étroite collaboration avec les analystes afin de leur faciliter la création et le traitement d'incidents de sécurité.

Le SOC et le CERT **travaillent** et **communiquent** ensemble (attacks, etc.).

En résumé, le **SOC** peut être considéré comme **la tour de contrôle** de la sécurité informatique de l'entreprise et le **CERT son allié** pour prendre en charge et traiter les **menaces avérées**.

Un SOC est donc la réalité qu'on ne peut pas arrêter toutes les attaques.

- **A tout moment, le système de sécurité le plus avancé peut échouer.**

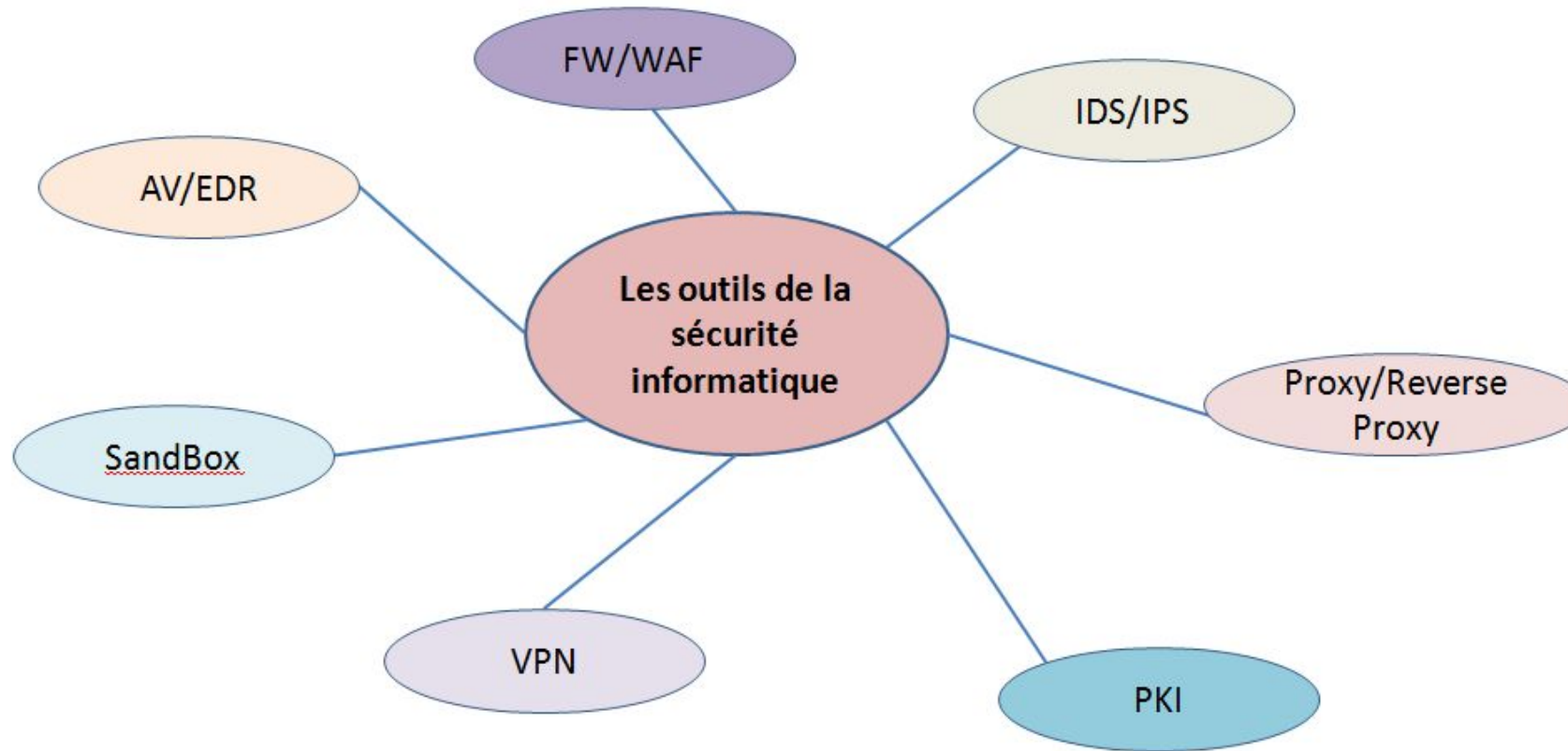
Dans ce cas, il faut limiter l'impact et sécuriser le périmètre attaqué.

جامعة باتنة
UNIVERSITY OF BATNA 2

Outils de gestion et de traitement d'incidents de sécurité en entreprise

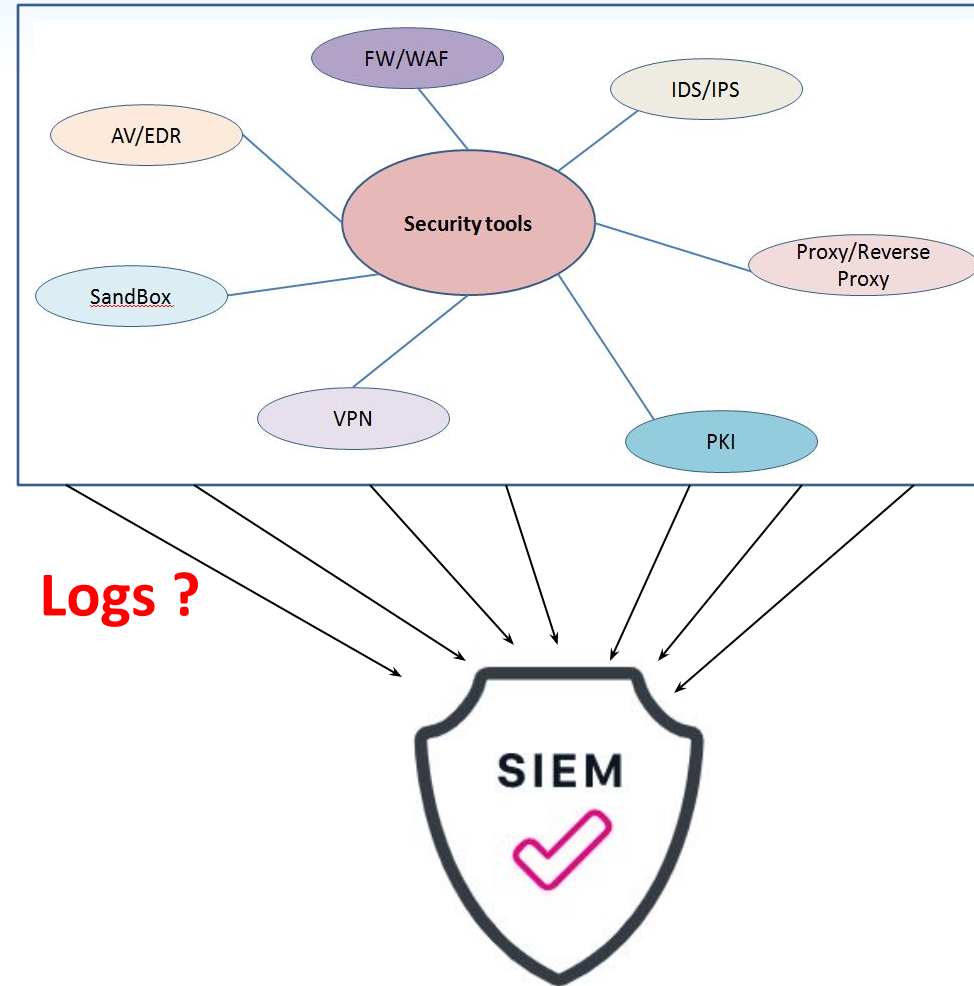
UNIVERSITY OF BATNA 2

Rappel



Comment les équipes de sécurité sont-elles alertées de chaque technologie (outil de détection)?

Réponse



So, logs, what are they?

Security Information and Event Management

Logs?

Définition de log

Les logs sont des **enregistrements de toutes actions faites dans un système informatique** (ordinateur, serveur, routeur, FW, AV, IPS/IDS, proxy, etc.), y compris les événements (par exemple, login, connexions vers un site externe, suppression d'un fichier, branchement clé USB, etc.).

Le log fournit une **trace historique** des activités qui peut être utilisée pour

- Comprendre le comportement du système (troubleshooting)
- Suivre les actions des utilisateurs (link click, login time, etc.)
- Identifier les incidents de sécurité
- Enquêter sur les violations potentielles (non-admin access, privilege escalation)

Toutes ces métadonnées sont enregistrées dans des fichiers appelés "**fichiers logs**" (file.log) et **peuvent être transmises et centralisées dans l'outil SIEM**.

Logs

Objectif de la collecte de logs en cybersécurité

La collecte de logs permet aux équipes de sécurité de

- surveiller ce qui se passe dans l'infrastructure informatique de l'entreprise
- identifier les anomalies et les risques du système (firewall misconfiguration,, etc.)
- troubleshooting, à l'audit, à la conformité, à la réponse aux incidents et au forensic.

La centralisation de tous les logs dans un seul outil (SIEM) **facilite l'investigation** des événements en cas d'incidents de sécurité.

Par conséquent, une **gestion et une analyse efficaces des logs est importante pour une détection efficace des menaces**.

Outre, les organisations s'appuient sur les logs pour maintenir un environnement informatique sûr et performant.

Logs

Anatomie des logs

Un log contient au minimum les informations sur

- **le temps où une action a été réalisée** sur un système informatique appelé "**Timestamp**"
- **l'utilisateur ou la machine** (nom de l'utilisateur ou l'adresse IP de la machine)
- **l'action entreprise** par le système/service/utilisateur en question.

Le contenu d'un log dépend du système qui le génère; **d'autres informations peuvent être incluses** dans le fichier log (par exemple, proxy → URL, AV → Hash, etc.).

Le proxy peut, par exemple, fournir d'autres logs comme: le site web visité, le domaine du site web, le **UserAgent**, l'IP de destination, le port de destination, l'action du proxy en question (bloqué or autorisé), etc.

Logs

Screenshot symantec (AV)

Exemple de log antivirus (log brute)

Log format

The expected format for this device is:

```
<date> [<device IP>] <date> SymantecServer <hostname>: <message>
```

Log sample

This is a sample log from a Symantec Endpoint Protection device:

```
Jan 01 01:01:01 [192.0.2.1] Jan 01 01:01:01 SymantecServer servername:,Category: 1,Symantec AntiVirus,Symantec  
Endpoint Protection services startup was successful.
```

Logs

Types de logs Chaque technologie génère un type de données différent

- Logs d'événements: est un log **de haut niveau** qui enregistre des informations sur le trafic et l'utilisation du réseau, telles que les tentatives de connexion, les tentatives de login échouées et les événements d'application.
- Logs serveur: est un document texte contenant un enregistrement des activités liées à un serveur spécifique pendant une période de temps spécifique.
- Logs système: ou **syslog**, est un enregistrement des événements du système d'exploitation. Il comprend les messages de démarrage, les modifications du système, les arrêts inattendus, les erreurs et les avertissements, ainsi que d'autres processus importants. **Windows, Linux et macOS génèrent tous des syslogs.**
 - **Windows: System, application, security**
 - **Linux: auditd (security): privilege escalation, unix (os): application and system of windows**
 - **FW: traffic,**
- Logs d'autorisation et d'accès: comprennent une liste de personnes ou de robots accédant à certaines applications ou à certains fichiers (e.g., robots/agents to check logins and deactivate accounts).
- Logs de modification: comprennent une liste chronologique des modifications apportées à une application ou à un fichier (mises à jour windows automatiques, cron jobs). Scheduled tasks in OS (attackers try to modify them)
- etc.

SIEM (Security Information and Event Management)

On a parlé d'une centralisation de logs sur un seul **outil** afin de faciliter l'investigation des analystes.

Cet outil est le plus indispensable pour le traitement d'incidents de sécurité, on parle de **SIEM**.



Phase de collecte de logs

- Mettre en place une infrastructure solide capable de collecter les différentes technologies générant les logs (windows: pull de l'agent SIEM, linux: push from agent)
- **Centralisant les différents systèmes dans le SIEM**
- On effectue la normalisation, standardisation, agrégation (DoS: sent once x times), filtrage, et parfois même la compression.

Phase de "correlation engine"

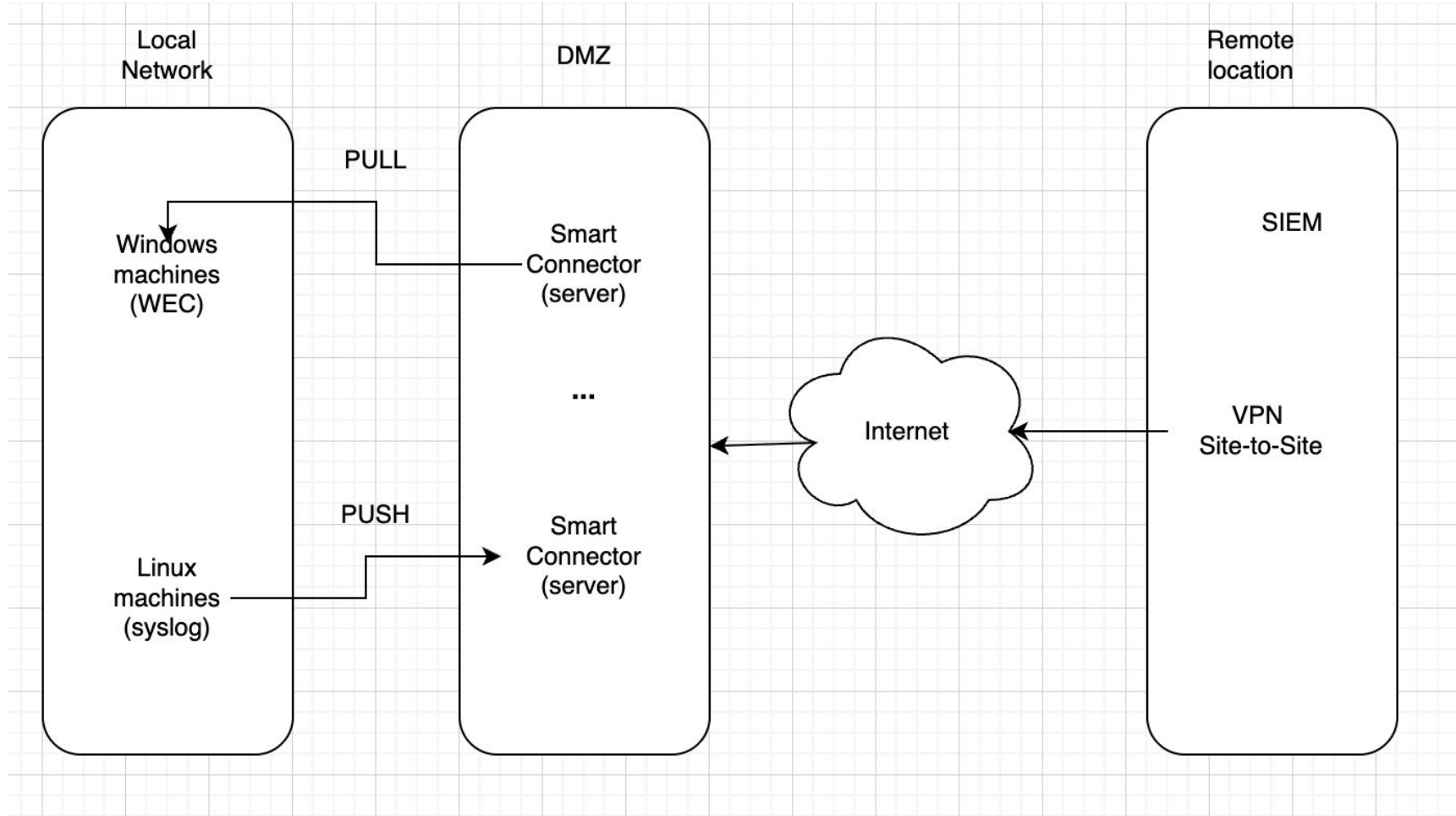
- On définit les UsesCases selon les besoins de l'entreprise.
- On définit donc un ou plusieurs UsesCases pour ne plus être aveugle à un risque bien défini.
- On procède également aux **Tuning** des règles de sécurité pour éviter les incidents de type FP ou flooding.

Phase de stockage ou d'archivage et réponse aux incidents

- **Lors de la phase de collecte, on filtre nos recherches.** Cependant, même avec le filtrage, on va chercher dans une base de données avec des millions de logs. Cela a poussé la plupart des entreprises à diviser les logs, par exemple, en stockant les logs de 3 à 6 mois dans un serveur, et les logs d'un an dans un autre serveur appelé "Archiver".

SIEM (Security Information and Event Management)

Exemple d'infrastructure



SIEM



Principales fonctionnalités de la phase de collecte (1/2)

- **Normalisation et parsing** : La normalisation est le processus qui consiste à obtenir, par exemple, l'IP source, le nom d'hôte, l'heure de la connexion, etc. à partir des événements bruts, et le parsing est le processus qui consiste à faire correspondre les logs à des règles.
- **Filtrage des événements** : pour choisir uniquement les événements qui nous intéressent au niveau de la technologie générant les logs et de transférer cet événement au SIEM.
- **Mise en cache** : lorsque la connectivité entre le collecteur du SIEM et la destination échoue pour une raison quelconque, le collecteur du SIEM pousse les logs dans le cache et reprend le transfert lorsque la connexion est établie.
- **Agrégation** : quand on a les mêmes événements qui se répètent, on envoie une seule fois l'événement avec le nombre d'occurrence de ce dernier.



Principales fonctionnalités de la phase de collecte (2/2)

- **Compression et cryptage** : ces deux fonctionnalités sont nécessaires pour compresser les logs et les crypter entre la source et la destination pour éviter d'envoyer les logs en clair car les logs contiennent des informations sensibles.
- **Contexte du client** : il est important de connaître le scope de la collecte, ce que le client souhaite collecter. On doit établir des priorités et voir quels dispositifs sont critiques, tels que : les FW, IPS, AV, etc. On collecte par la suite les logs selon cette priorisation car problèmes si on collecte tout vu la taille gigantesque des logs.
- **Autres informations à savoir du client** : On doit savoir comment le réseau est construit, où sont hébergées les données, si le client a d'autres applications qu'on doit prendre en compte, avec qui communiquer si nécessaire?, etc.

SIEM

Exemples de SIEM

- QRadar (IBM => Palo Alto): Palo Alto Networks completed the acquisition of IBM's QRadar SaaS assets in September 2024
- Splunk (Cisco)
- Exabeam
- Sentinel (Microsoft)
- Arcsight
- Netwitness (RSA)
- LogScale (Falcon)
- etc.

SIEM

IBM QRadar

Dashboard

Offenses

Log Activity

Network Activity

Assets

Reports

Admin

System Time: 12:45 PM

Offenses

My Offenses

All Offenses

By Category

By Source IP

By Destination IP

By Network

Rules

All Offenses > Offense 10 (Summary)

Offense 10

Summary Display Events Flows Actions Print Send to Pulse Policy Secure

Magnitude		Status		Relevance	0	Severity	7	Credibility	3
Description	FileType Detected	Offense Type	Source IP						
		Event/Flow count	3 events and 0 flows in 1 categories						
Source IP(s)		Start	Sep 9, 2019, 1:13:03 PM						
Destination IP(s)		Duration	9m 14s						
Network(s)	Net-10-172-102 Net 10 0 0 0	Assigned to	Unassigned						

Offense Source Summary

IP		Location	Net-10-172-102 Net 10 0 0 0						
Magnitude		Vulnerabilities	0						
Username	Unknown	MAC Address	Unknown NIC						
Host Name	Unknown								
Asset Name	Unknown	Weight	0						
Offenses	1	Events/Flows	3						

Exemple de logs parsés dans le SIEM QRadar

IBM QRadar

Dashboard Offenses Log Activity Network Activity Assets Reports Admin System Time: 12:45 PM

Offenses

My Offenses

All Offenses

By Category

By Source IP

By Destination IP

By Network

Rules

All Offenses > Offense 10 (Summary)

Offense 10

Summary Display Events Flows Actions Print Send to Pulse Policy Secure

Magnitude		Status		Relevance	0	Severity	7	Credibility	3
Description	FileType Detected	Offense Type	Source IP						
		Event/Flow count	3 events and 0 flows in 1 categories						
Source IP(s)	10.0.0.74.100	Start	Sep 9, 2019, 1:13:03 PM						
Destination IP(s)	10.0.0.10.114	Duration	9m 14s						
Network(s)	Net-10-172-102 Net 10 0 0 0	Assigned to	Unassigned						

Offense Source Summary

IP	10.0.0.74.100	Location	Net-10-172-102 Net 10 0 0 0
Magnitude		Vulnerabilities	0
Username	Unknown	MAC Address	Unknown NIC
Host Name	Unknown		
Asset Name	Unknown	Weight	0
Offenses	1	Events/Flows	3

SIEM

ANOMALIES, NOT CORRELATIONS

RULES	TRIGGER FREQUENCY	RISK LEVEL
Abnormal MAC for user Abnormal network logon from this MAC for user	Not triggered	Critical (10)
Abnormal activity from country for group This is an abnormal country for a member of this group to perform activity	Not triggered	Critical (10)
Abnormal activity from country for organization This is an abnormal country for a member of this organization to perform activity	Not triggered	Medium (5)



SESSIONS, NOT EVENTS

10:05	Process execution: chrome.exe		
10:14	2x Web Activity		
10:26	Remote access to us-apps-dev1		
10:40	Web access to www.linkedin.com		
11:20	Web access to dilknlnlkaa.zoomer.cn	First time a user is accessing an internet IP address in this country China	+5
		First access to an internet IP address in this country China for the organization	+5
11:21	Process execution: barbarian.jar	Process barbarian.jar has been executed from a temporary directory	+5
		First execution of process barbarian.jar	+3
		First execution of process barbarian.jar in this organization	+3

SIEM



SESSIONS, NOT EVENTS

10:05	Process execution: chrome.exe		
10:14	2x Web Activity		
10:26	Remote access to us-apps-dev1		
10:40	Web access to www.linkedin.com		
11:20	Web access to dlknknlnkaa.zoomer.cn	First time a user is accessing an internet IP address in this country China	+5
		First access to an internet IP address in this country China for the organization	+5
11:21	Process execution: barbarian.jar	Process barbarian.jar has been executed from a temporary directory	+5
		First execution of process barbarian.jar	+3
		First execution of process barbarian.jar in this organization	+3

Outils de ticketing

Cet outil est utilisé non seulement par les analystes sécurité et le CERT, **mais aussi par le support IT.**

Dans ce cours, on se concentre sur son utilisation pour la réponse aux incidents de sécurité de façon générale.

Un système de ticketing **est un logiciel (ou interface) d'assistance utilisé pour la création des incidents de sécurité, le traitement, la gestion, et le suivi de la résolution d'incidents de bout en bout de façon efficace.**

Les analystes de sécurité l'utilisent également pour **communiquer avec les utilisateurs concernés** par l'incident de sécurité et **ainsi assurer un traçage de toute communication et résolution des incidents.**

Un incident de sécurité interne est une information strictement confidentielle et ne devrait en aucun cas devenir publique. **L'outil de ticketing avec ces classifications pourrait garantir la confidentialité des incidents de sécurité (critique => chiffré => payant).**

Quiz Time

Q1. Un firewall vous permet de

- a) Bloquer une connexion venant de l'extérieur.
- b) Bloquer une connexion vers l'extérieur.
- c) protéger votre réseau d'un virus interne.

Quiz Time

Q2. Un proxy

- a) Empêche une connexion vers un site malveillant.
- b) Empêche un attaquant de se connecter à la DMZ.
- c) Se base sur le filtrage au niveau de la couche 7.

Quiz Time

Q3. L'utilisation d'un VPN assure une protection contre le téléchargement de fichier/logiciel malveillant

- a) Oui étant donné que la connexion est chiffré.
- b) Non, le VPN chiffre la connexion réseau mais n'empêche pas l'installation de logiciel malveillant.
- c) Le VPN a deux modes de fonctionnement: un pour protéger et l'autre pour chiffrer.

Quiz Time

Q4. Pour se protéger contre les virus, vous proposez

- a) Un antispam
- b) Un pare-feu
- c) Un antivirus

Quiz Time

Q5. L'IPS vous permet de

- a) Détecter les intrusions et les prévenir.
- b) Supprimer les virus informatiques.
- c) Détecter les intrusions sans les prévenir.

Quiz Time

Q6. PKI (Public Key Infrastructure)

- a) Utilisé pour délivrer des certificats numériques.
- b) Permet d'authentifier un site web.
- c) basé sur la cryptographie à clé publique.

Quiz Time

Q7. Quels sont les problèmes résolus par le SIEM ?

- a) Le manque de méthodes d'authentification.
- b) Le long délai pour découvrir les failles de sécurité.
- c) La complexité des technologies et la difficulté d'identifier les attaques.

Quiz Time

Q8. L'outil de ticketing permet aux analystes de

- a) Créer, traiter, suivre et tracer les incidents de sécurité.
- b) Faire une investigation sur les causes d'un incident de sécurité.
- c) Regrouper les incidents de sécurité sur un seul outil.

Quiz Time

Q9. Une UseCase

- a) C'est la phase d'agrégation de données.
- b) C'est une règle de sécurité implémentée sur l'outil de ticketing.
- c) C'est une règle de sécurité implémentée au niveau du SIEM permettant le déclenchement d'une alerte.

Quiz Time

Q10. Quelles sont les fonctions de base d'un SIEM?

- a) La collecte, la normalisation et le stockage de log et alertes.
- b) Gérer les informations réseau et alertes.
- c) Gérer les événements réseau et alertes.

Quiz Time

Q11. Le SIEM permet de

- a) Bloquer les IPs malveillantes entrantes.
- b) Bloquer les scans non légitimes.
- c) Bloquer l'accès aux URLs malicieuses.
- d) Aucune réponse n'est correcte.

Quiz Time

Q13. Une Use Case permet

- a) Le blocage des IPs malveillantes sortantes.
- b) Le blocage des scans non légitimes.
- c) Le blocage d'accès aux URLs malicieuses.
- d) Aucune réponse n'est correcte.

Quiz Time

Q14. Une alerte scan s'est déclenchée sur le SIEM et après investigation, vous trouvez que l'IP est malveillante, que faites vous ?

- a) Blacklister l'IP au niveau du pare-feu.
- b) Blacklister l'IP au niveau du SIEM.
- c) Blacklister l'IP au niveau de l'outil de ticketing.
- d) Aucune réponse n'est correcte

Associer chaque attaque à sa description

Quiz Time

Attaque	Description
a- Phishing	1- Un type de malware qui permet de chiffrer tous les documents et fichiers du système infecté.
b- DDOS	2- Ce type d'attaque peut rendre une machine ou tout un réseau totalement indisponible.
c- ARP Spoofing	3- Vole les ressources (puissance de calcul) d'un système infecté afin de générer des cryptomonnaies.
d- SCAM	4- Désigne la modification de la présentation d'un site web sans autorisation suite à un piratage de ce dernier.
e- Ransomware	5- L'attaquant utilise un botnet pour réussir l'attaque et peut rendre une machine ou tout un réseau totalement indisponible.
f- Keylogger	6- Consiste à rediriger le trafic réseau d'une ou plusieurs machines vers la machine du pirate en corrompant le cache ARP d'une machine victime.
g- Cryptominers	7- Technique d'ingénierie sociale, consiste à récupérer des informations personnelles (carte de crédit, mot de passe, etc.), et l'attaquant se fera passer par une entité légitime.
h- SPAM	8- technique et d'escroquer les internautes en se faisant passer par un héritier par exemple
i- Cross Site Scripting (XSS)	9- Enregistre tout ce qu'un utilisateur tape sur son clavier et l'envoie à son propriétaire.

Questions?

SOAR (Security Orchestration, Automation, and Response)

Définition: Le SOAR est un "add-on" qui peut être ajouté au SIEM (does not work alone), qui répond aux besoins les plus classiques (basiques et pas critiques, replace L1, reduce L1 analysts) du SOC (detection malware, analyse email (report button), IP reputation, etc.) et permet d'automatiser l'investigation et la réaction sans assistance humaine.

On prend un exemple parmi les cas les plus basiques qui est le cas des mails de phishing.

Ces derniers sont généralement traités manuellement.

Où l'analyste passait beaucoup de temps à analyser l'adresse source de ce mail, chaque lien, chaque pdf, les liens cachés dans un pdf où derrière une image.

Ensuite, l'analyste devrait regrouper toutes ces informations et essaie de formuler une réponse unique pour chaque utilisateur (can be or not a security incident, clicked or not).

SOAR (Security Orchestration, Automation, and Response)

Le but d'une solution SOAR est **d'automatiser toutes ces étapes**, avec la possibilité de faire des actions à distance (**e.g., sur ces mails de phishing**).

Par exemple

- **supprimer tous les mails avec une pièce jointe** malicieuse attachée reçus dans le parc informatique de l'entreprise,
- **interdire l'accès au site malveillant** reçu par mail et éventuellement
- supprimer un fichier malveillant présent dans toutes les stations de travail.

Toutes ces actions peuvent être effectuées à l'aide de **la conception de playbook**, et bien sûr avec l'accord en amont du client final.

Pour l'exemple de mails de phishing, on est non seulement sur l'automatisation de la réponse (e.g., email, jira) mais aussi sur l'automatisation de l'investigation (if-else, virustotal, etc.).

SOAR

Un **playbook** est **l'ensemble de processus (workflow) par lesquels un incident douteux doit passer pour confirmer sa légitimité ou pas.**

Il définit les étapes à suivre depuis la réception de l'incident jusqu'à son traitement (siem, email protection, email).

Mettre en place des playbooks est **un projet qui prend du temps**. Avant de mettre en place une solution SOAR, il **faut d'abord commencer par la détection car sans cette dernière ça sert à rien d'avoir la partie réponse.**

Néanmoins, une solution SOAR vient souvent avec des **playbooks de base** mais qui nécessite une personnalisation pour être efficace.

Exemples de solutions SOAR: Exabeam, Cortex (Palo Alto), Phantom, Resilient (IBM), Fusion (Falcon), etc.

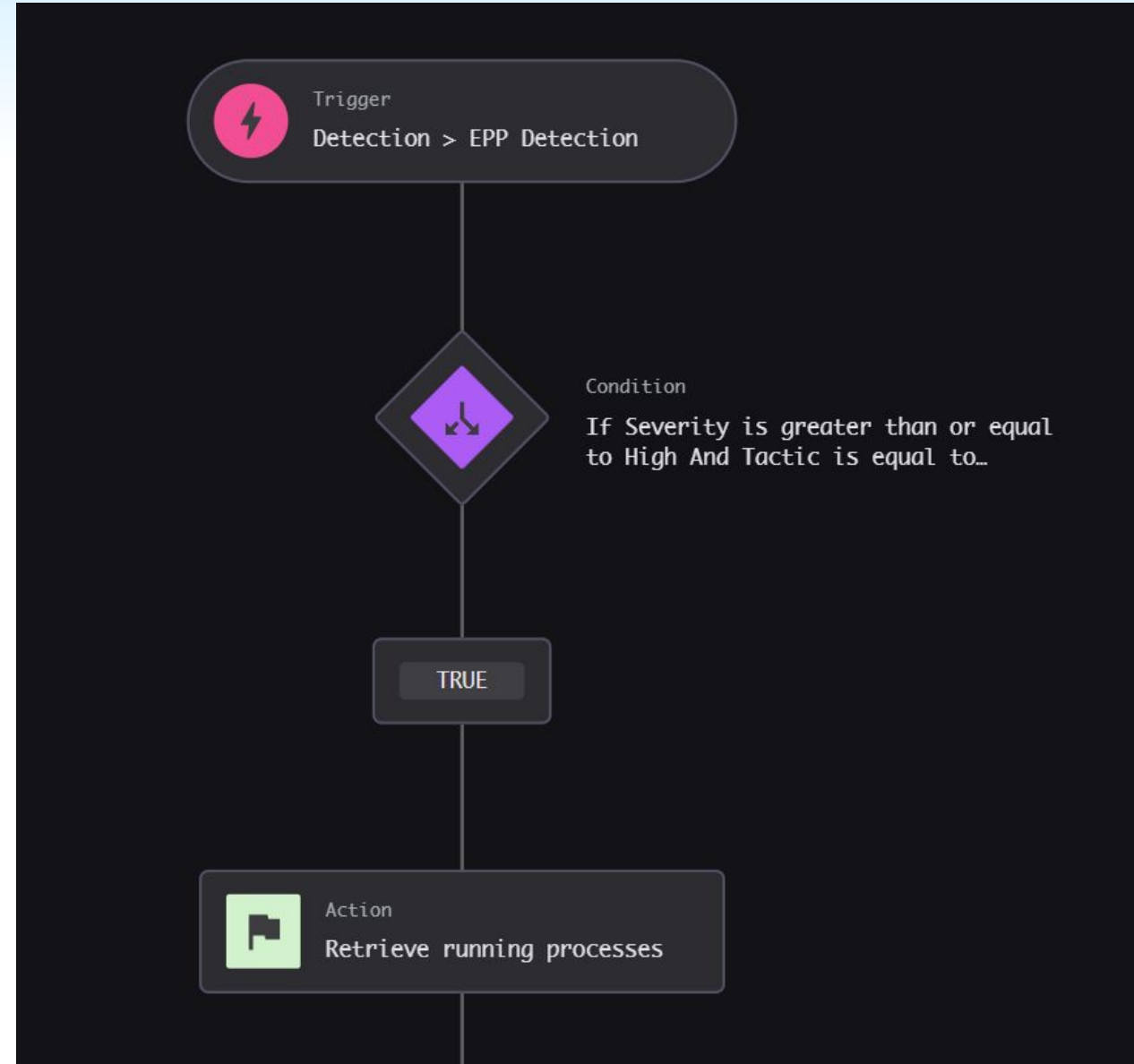
The Use of SOAR in each case: Email (mature), siem detection (a bit mature), IPS (not yet)

SOAR: Playbook Exabeam

SOPHISTICATED RESPONSE AUTOMATION

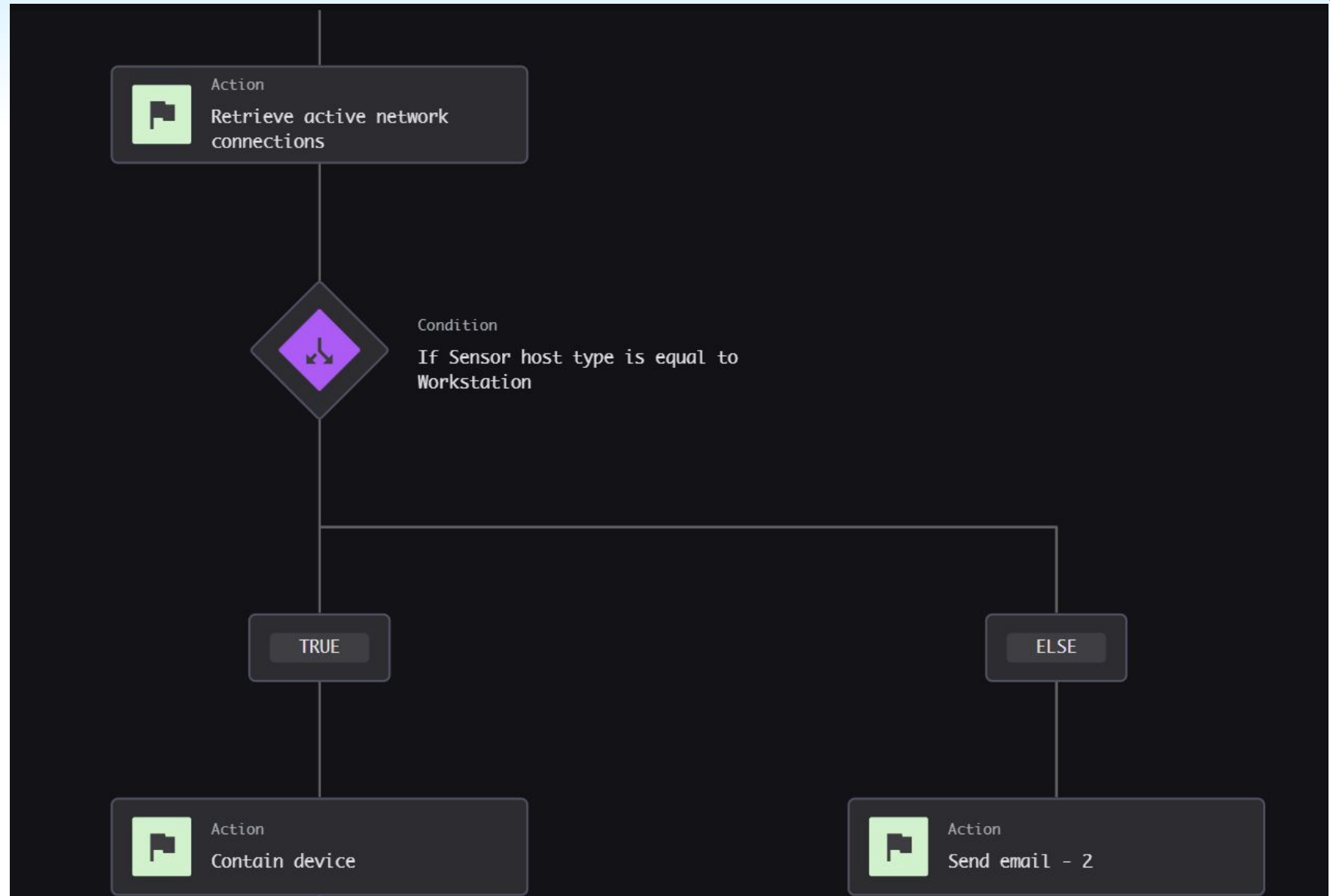


SOAR: Playbook Fusion (CrowdStrike)

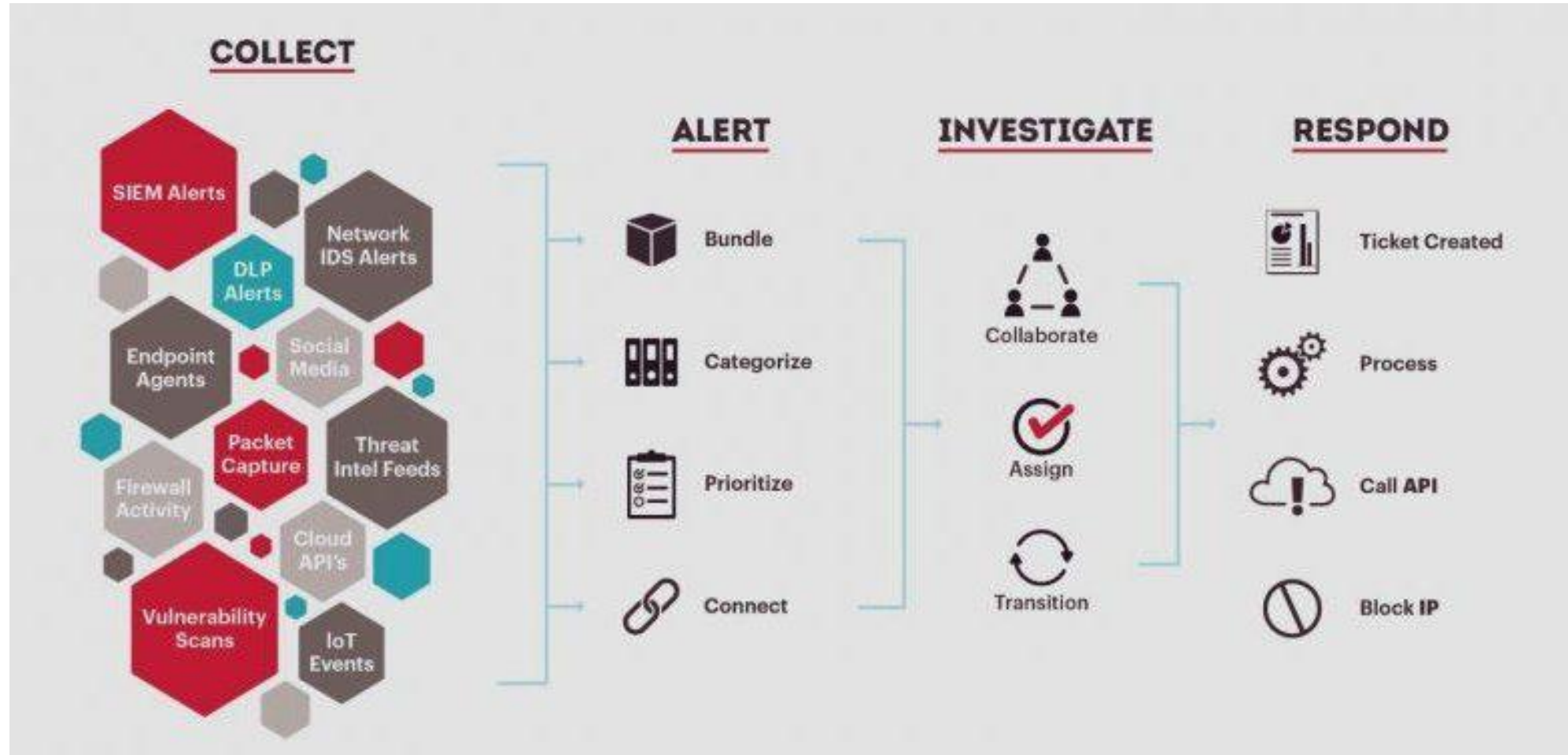


SOAR: Playbook Fusion (CrowdStrike)

This part is related
to the previous one

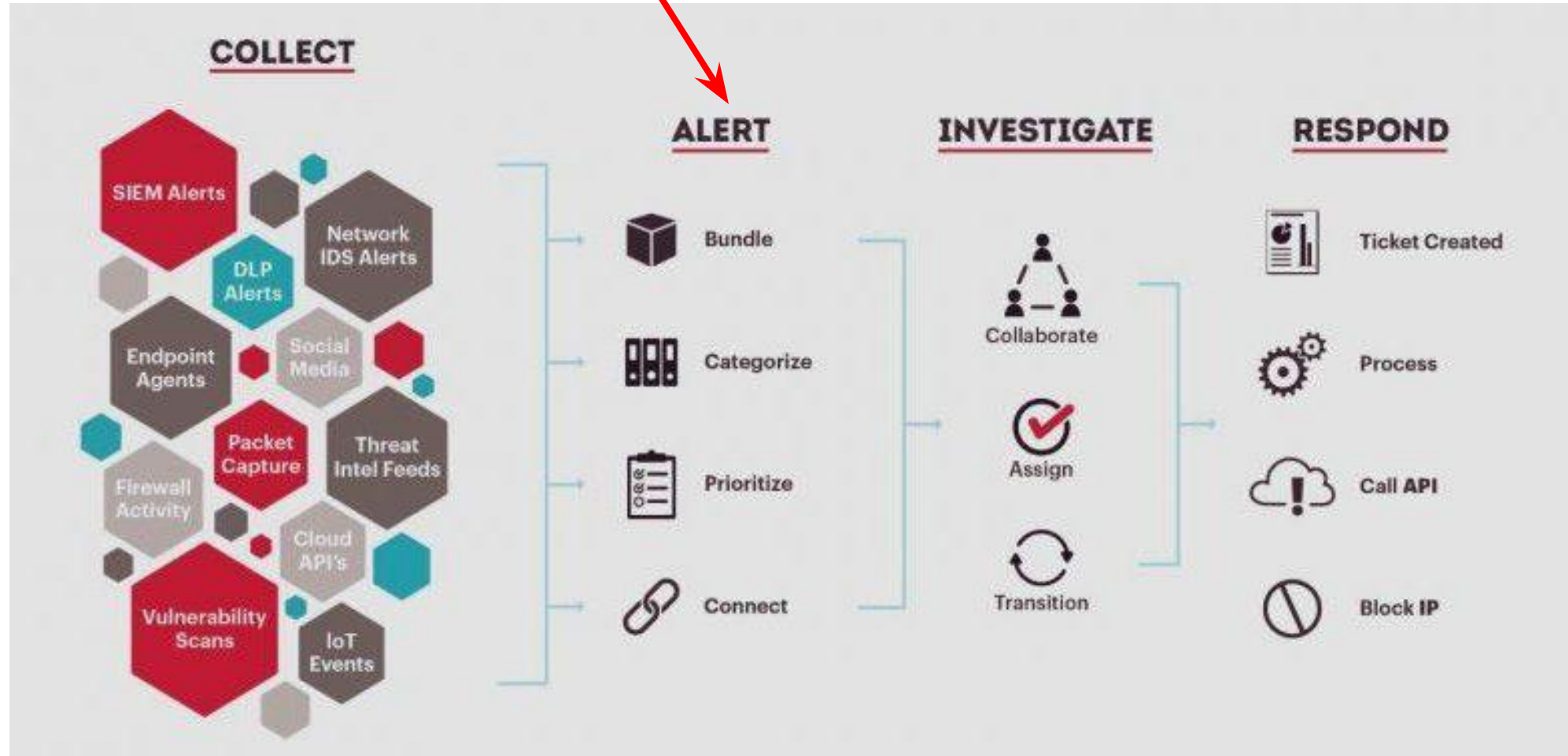


Résumé



Steps from the collect of the ~~information~~ logs to the response

How can we get the security alerts at the SIEM Level ?



Création d'alertes de sécurité au niveau SIEM (UCs)

Création d'alertes de sécurité au niveau SIEM (UCs)

Avant la création des Usecases, les analystes ainsi que l'équipe intégration doivent mettre en place une réunion avec le métier demandant la création de usecases.

Durant cette réunion, ils discutent de la faisabilité et des besoins du métier. Une fois cette étape faite, l'équipe intégration se charge de récupérer les logs de la technologie en question et de mettre en place la usecase. Cette dernière doit être implémentée **sur la pré-production du SIEM** pendant environ 15 jours afin **d'éviter les faux positifs et les bruits (e.g., 15 to 20 times triggered => obsolete usecase, to be reworked)**.

Pendant ces 15 jours, c'est un analyste de sécurité qui suit et surveille les déclenchements éventuels de la usecase et le bon fonctionnement de cette dernière.

Une fois les 15 jours passés et que la usecase est correctement opérationnelle, l'équipe intégration **passe la usecase en production sur le SIEM**.

Création d'alertes de sécurité au niveau SIEM (UCs)

La création de Usecases sur le SIEM **permet de détecter et d'identifier le plus en amont possible**

- une tentative d'attaque
- une exfiltration de données (DLP, Firewall big data transfered)
- un comportement anormal sur le réseau (IPS/IDS), sur une machine utilisateur (EDR, HIPS/HIDS, EPP), sur un serveur, etc.

Ensuite, répondre en étant préparé à réagir en cas d'incident de sécurité (attaque virale, DDoS, phishing, etc.) à travers **un processus de gestion et de réponse à incident prédéfini** (fiche reflexe).

Création d'alertes de sécurité au niveau SIEM (UCs)

Exemple de règle (Usecase) sur le SIEM QRadar

Which attack are we trying to detect

Apply . *****

When the event(s) were detected by one of FIREWALL-list
and NOT when any of Source IP are contained in any of whitelisted_IPs
and when at least **400** events are seen with the same Source IP in 1 minute

Une fois les **conditions** de la règle sont **atteintes**, **une alerte se déclenche sur le SIEM** et l'analyste de sécurité devrait investiguer et traiter l'incident de sécurité.

Création d'alertes de sécurité au niveau SIEM (UCs)

Exemple de règle (Usecase) sur le SIEM QRadar

Apply .DOS Attack Detection

When the event(s) were detected by one of FIREWALL-list

and NOT when any of Source IP are contained in any of whitelisted_IPs

and when at least 400 events are seen with the same Source IP in 1 minute

Une fois les **conditions** de la règle sont **atteintes**, **une alerte se déclenche sur le SIEM** et l'analyste de sécurité devrait investiguer et traiter l'incident de sécurité.

Création d'alertes de sécurité au niveau SIEM (UCs)

Exemple de règle (Usecase) sur le SIEM QRadar:

Apply .DOS Attack Detection

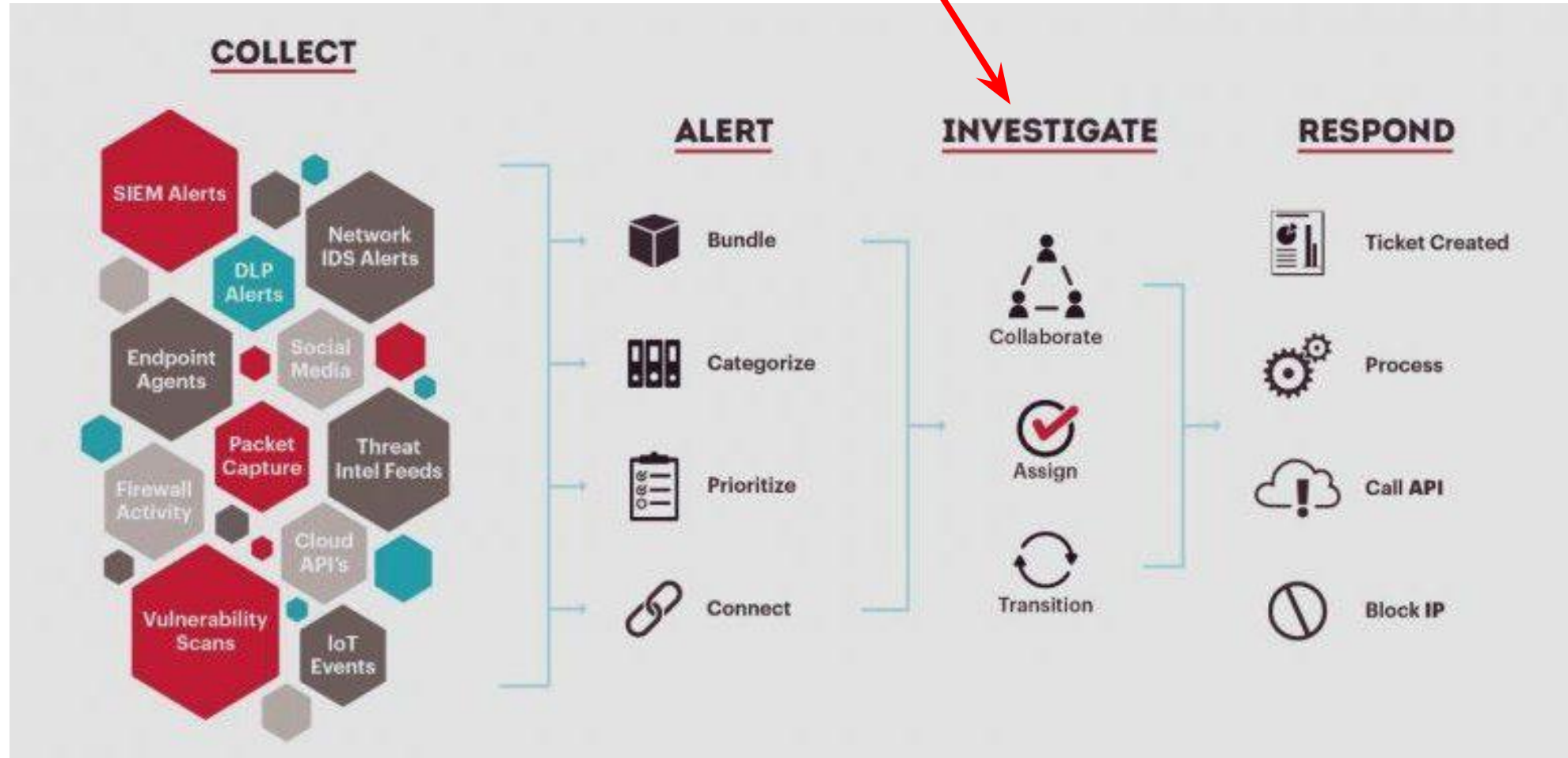
When the event(s) were detected by one of FIREWALL list
and NOT when any of Source IP are contained in any of whitelisted_IPs
and when at least 400 events are seen with the same Source IP in 1 minute

Une fois les **conditions** de la règle sont **atteintes**, **une alerte se déclenche sur le SIEM** et l'analyste de sécurité devrait investiguer et traiter l'incident de sécurité.

Donner un exemple d'un outil d'investigation?

The steps from the collect of the information logs to the response

Where do the analysts investigate?



Traitement d'incidents de sécurité par les analystes en entreprise

Traitement d'incidents de sécurité par les analystes

Après avoir vu comment les analystes de sécurité peuvent créer les usecases sur le SIEM et le passage en production, dans cette partie, nous **allons voir comment les analystes les traitent de bout en bout.**

Différentes étapes de traitement

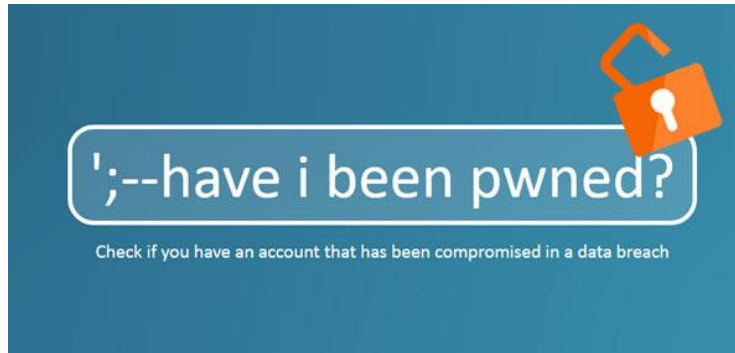
- a) Déclenchement de l'alerte au niveau du SIEM.
- b) Investigation et outils interne et/ou externe: l'analyste devrait investiguer sur les causes du déclenchement de l'alerte en faisant des recherches sur le SIEM et en **essayant de suivre la chronologie de la détection (avant, pendant, et après).**

Investigation: understand the attacker mindset (not just legitimate or not)
- Defense harder than attack

=> L'analyste ne devrait en aucun cas utiliser des outils externes pour chercher des informations internes (sensibles) de l'entreprise.

Par exemple: privilégier l'analyse d'un fichier dont on connaît pas le contenu par une sandBox interne qu'externe (cuckoo, virusTotal License, App.run.any, Hybrid, joeSandBox (5 free per year), etc.).

Investigation tools



Traitement d'incidents de sécurité par les analystes

- c) Classification (incident avéré ou pas): Une fois **l'investigation terminée**, l'analyste devrait donner **son verdict sur la légitimité ou pas de l'incident de sécurité**.
- Si l'incident déclenché est légitime (par exemple, audit interne), l'analyste ferme l'incident de sécurité sans aucune action de sa part tout en le traçant sur l'outil de ticketing (ticket automatique ou pas, write the investigation steps and reason for incident closure).
 - Si l'incident n'est pas légitime, l'analyste devrait l'ouvrir (i.e., l'envoyer) sur l'outil de ticketing et l'affecter à l'utilisateur ou le métier concerné pour appliquer les recommandations du SOC (assigned-to). (seen by all analysts)
 - L'incident de sécurité ouvert doit avoir un **titre**, **description de l'incident**, les **recommandations SOC (supprimer email, full AV scan, sensibilisation, etc.)**, ainsi que la **criticité de l'incident** (basse, moyenne ou haute).

Traitement d'incidents de sécurité par les analystes

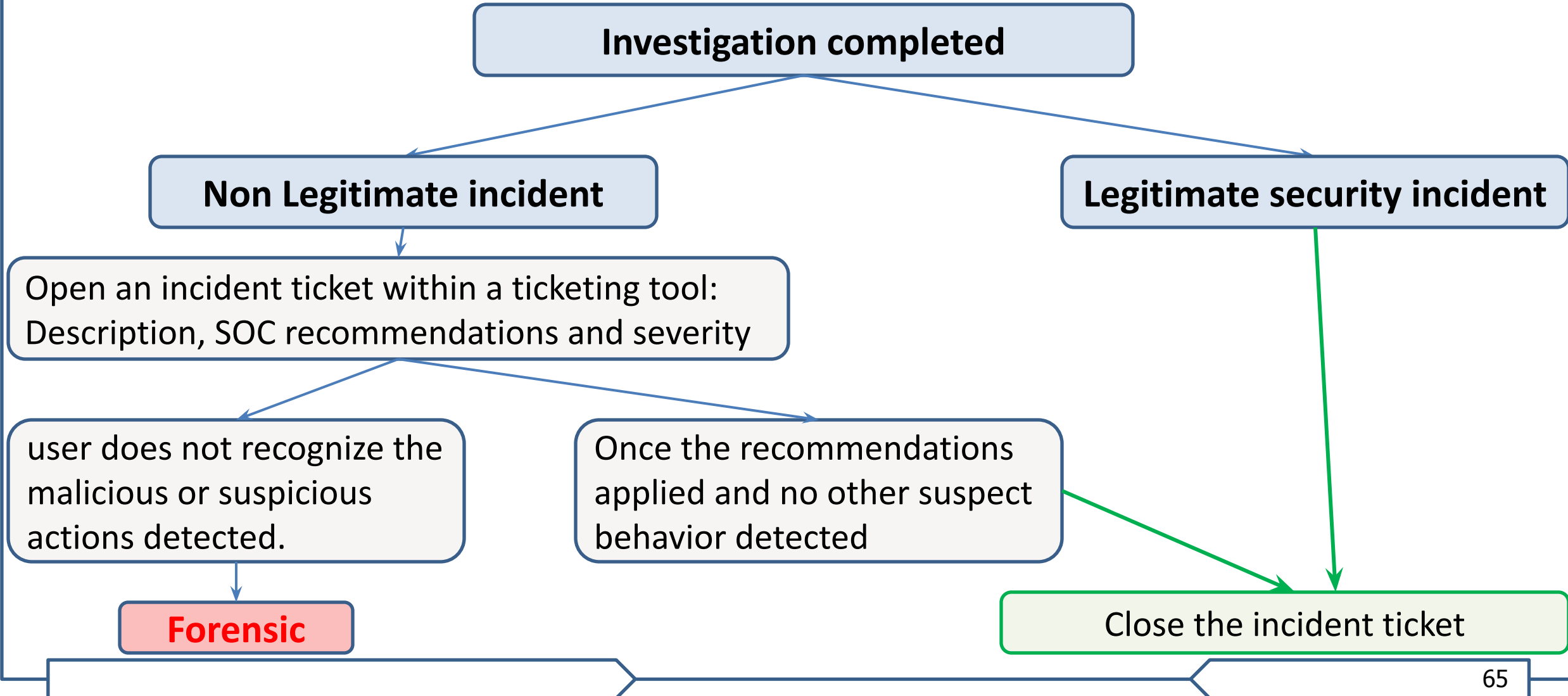
c) Classification (incident avéré ou pas)

- Une fois l'incident de sécurité est ouvert, l'utilisateur concerné va recevoir un mail (to ensure reception) l'informant qu'il a des recommandations à suivre sur l'outil de ticketing suite à un incident de sécurité sur la machine ou le serveur dont il est responsable.
- Une fois les recommandations appliquées, il fait un retour au SOC via l'outil de ticketing (received by all analysts).
- Si toutes les recommandations ont été appliquées et que le SOC n'identifie pas d'autres risques de sécurité, l'incident pourrait alors être clôturé.
- Si par exemple l'utilisateur ne reconnaît pas les actions malicieuses ou douteuses détectées par le SOC (par exemple, création d'un compte admin, communication vers une IP malicieuse), une analyse plus poussée devrait être faite sur la machine elle même. on parle d'une analyse **Forensic**.

Security incidents processed by analysts

The various processing stages

c) Classification (proven incident or not)



Traitement d'incidents de sécurité par les analystes

Incidents de sécurité : gestion d'incidents de sécurité

Un processus de gestion d'incidents de sécurité permet de

- Réagir rapidement et de réduire l'impact en cas d'incident
- Améliorer la prévention et la sensibilisation
- Détecter et identifier les incidents
- Améliorer le niveau de sécurité.

Exemple de réaction en cas d'une infection virale

- Déconnecter le poste du réseau ou d'Internet, sans l'éteindre (No AV scan => or deleted!)
- S'assurer que l'antivirus/antimalware est à jour avec les dernières signatures
- Exécuter le scan complet avec un antivirus
- Contacter un spécialiste au besoin
- Chercher à identifier la cause.

Outils de ticketing: Archer Exemple

IT Security Risk Management ▾ Issues Management ▾ PCI Management ▾ Business Resiliency ▾ Regulator

Security Incidents : INC-358933

EDIT

VIEW

Last Updated: 6/21/2019 12:45 PM Archer, Corey

Record 4

Incident ID: INC-358933

Title: RSA NetWitness C2 Domain (New2)

Incident Summary: RSA NetWitness C2 Domain grouped by source IP:192.168.10.201 and destination IP:95.57.120.128

Incident Details: This incident is based on the rule RSA NetWitness C2 Domain and based on the aggregation criteria source IP - destination IP

▼ INCIDENT STATUS

Date Created: 5/2/2018 11:39 AM

Date/Time Modified: 5/2/2018 3:47 PM

Date/Time Closed:

Days Open: 47 Day(s)

No. of Aggregated Alerts: 95

IT Security Risk Management ▾ Issues Management ▾ PCI Management ▾ Business Resiliency ▾ Regulatory and Co

Security Incidents : INC-358933

EDIT

VIEW

Updated: 6/21/2019 12:45 PM Archer, Corey

Record 4 of 75

Overview

Alerts

Incident Response Tasks

Incident Journal

AGE BY STATUS (MINUTES)

INITIAL THREAT CLASSIFICATION

Threat Category: Malware
└ C2

Threat Actor: External

Threat Vector: Hacking
└ Backdoor or C2

• PRIORITY OVERRIDE

• RELATED MAPPINGS

▼ INCIDENT REPORTING

Attach to InfoSec Briefing: No

Sécurité : [REDACTED]



Détails

Data Feed Service, Archer

Synthèse: [REDACTED] Execution - Antivirus : Multiple re-occurrence of the same infection identified from same host containing Virus Detected [REDACTED]

Description: Bonjour,

Le mardi 15 mars 2022 à 11:43 plusieurs virus ont été détectés sur l'asset [REDACTED] pendant que l'utilisateur [REDACTED] était connecté.

Chemin(s) détecté(s) :

C:\User\ [REDACTED] \Downloads\dropfiles\Drops\BANKING DETAILS.pdf.exe

Hash :

6BAD86AA8B55D18A2EC3278C3F53CFAA562BF75E5CBA33B907C90C7A9605BAF5

Action de l'antimalware : Quarantined, Details pending // //

La source du fichier est par le biais de c:/windows/explorer.exe,

Les hashes de ces fichiers est connu de virustotal. 24/67

L'antivirus a mis en quarantaine les fichiers.



Cordialement.

—

Vous trouverez ci-dessous la log source et un exemple de log brut



Notes de l'analyste: [REDACTED]



Conclusion

La sécurité est un travail d'équipe.

La **coopération** et **l'échange d'informations** restent indispensables pour parvenir à améliorer la sécurité des organisations.

Résumé

L'alerte

L'investigation

La création des incidents

- cas non avéré : fermeture et fine tuning, FP, audit, ...

- cas avéré : création d'un incident de sécurité, recommandations, analyse forencis, ...

Combien d'alertes les analystes traitent par jour ? (tout dépend de la taille de l'entreprise et l'efficacité des UCs mises en place)